



Lecturer: Nadim Kobeissi

Website: <https://appliedcryptography.page>

Problem Set 2: Symmetric Cryptography

Instructions: This problem set covers topics in provable security from topics 1.4^a, 1.5^b and 1.6^c of the course. Submit your solutions as a neatly formatted PDF. You are encouraged to collaborate with classmates in studying the material, but your submitted solutions must be your own work. For proofs, clearly state your assumptions, steps, and conclusions.

^a<https://appliedcryptography.page/slides/#1-4>

^b<https://appliedcryptography.page/slides/#1-5>

^c<https://appliedcryptography.page/slides/#1-6>

1 Pseudorandomness

1. (10 points) Pseudorandom Generators

- (5 points) Explain the limitations of the one-time pad for practical encryption and why pseudorandom generators (PRGs) are needed in modern cryptographic systems.
- (5 points) Analyze the security implications of the following PRG construction, where G is a secure PRG:

$$H(S) = A \| B \| C \| D \text{ where } A \| B = G(S) \text{ and } C \| D = G(B)$$

Determine whether H is a secure PRG. If not, provide a distinguisher that can tell apart $H(S)$ from a truly random string with non-negligible advantage.

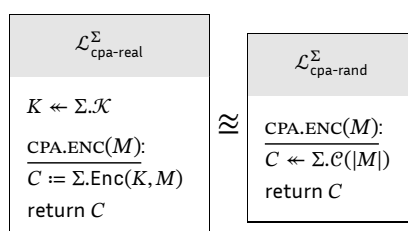
2. (10 points) Pseudorandom Functions and Permutations

- (5 points) Consider the following PRF construction: $F(K, X) = G(K) \oplus X$, where G is a secure PRG. Is F a secure PRF? If not, describe a distinguisher that can effectively tell F apart from a random function.
- (5 points) Compare and contrast PRFs and PRPs:
 - Explain the key differences in their definitions and properties.
 - Describe how PRPs can be “downgraded” to PRFs, but not necessarily vice versa.
 - Explain why collisions are inevitable for PRFs but not for PRPs.

2 Chosen-Plaintext and Chosen-Ciphertext Attacks

1. (10 points) CPA Security

- (5 points) Consider the CPA security definition:



- i. Explain why deterministic encryption schemes always fail CPA security.
 - ii. Construct a simple distinguisher program that can break the CPA security of any deterministic encryption scheme.
 - iii. Analyze what practical security vulnerabilities exist in systems that use non-CPA-secure encryption.
 - (b) (5 points) For each of the following encryption schemes, determine whether it achieves CPA security. If not, provide a specific attack:
 - i. $\text{Enc}(K, M) = (R, F(K, R) \oplus M)$ where $R \leftarrow \{0, 1\}^\lambda$ and F is a secure PRF.
 - ii. $\text{Enc}(K, M) = (R, F(K, M) \oplus R)$ where $R \leftarrow \{0, 1\}^\lambda$ and F is a secure PRF.
 - iii. AES in Electronic Codebook (ECB) mode.
 - iv. AES in Counter (CTR) mode with a randomly chosen IV.
2. (10 points) **CCA Security and Authenticated Encryption**
- (a) (3 points) Format oracle attacks:
 - i. Explain how the null-oracle attack works against CTR mode encryption and why it's devastating despite CTR mode being CPA-secure.
 - ii. Describe a real-world scenario where a format oracle might be inadvertently exposed in a cryptographic system.
 - iii. Calculate the approximate number of oracle queries needed to recover a 1 KB file using the null-oracle attack, and explain why this is practical for an attacker.
 - (b) (4 points) For the following encryption scheme constructions, determine whether each provides CCA security and/or authenticated encryption (AE). Justify your answers with brief explanations:
 - i. Encrypt-then-MAC: $C = \text{Enc}(K_e, M)$, $T = \text{MAC}(K_m, C)$, output (C, T)
 - ii. Encrypt-and-MAC: $C = \text{Enc}(K_e, M)$, $T = \text{MAC}(K_m, M)$, output (C, T)
 - iii. MAC-then-encrypt: $T = \text{MAC}(K_m, M)$, $C = \text{Enc}(K_e, M \| T)$, output C
 - iv. Explain a scenario where replay attacks could succeed even against a system using authenticated encryption, and how associated data (AD) addresses this vulnerability.
 - (c) (3 points) AES-GCM (Galois/Counter Mode):
 - i. Explain how AES-GCM combines CTR mode encryption with Galois field multiplication for authentication. What security advantages does this provide over using separate encryption and MAC algorithms?
 - ii. Describe the critical security implications of nonce reuse in AES-GCM. What specific vulnerabilities arise when the same nonce is used for multiple messages?
 - iii. AES-GCM is sometimes implemented with different tag lengths. Analyze the security tradeoffs when using 128-bit tags versus 64-bit or 32-bit tags.
 - iv. Aside from nonce reuse, what is an unexpected vulnerability in AES-GCM that developers and engineers might not be aware of, but that might significantly impact the security of their software?

3 Collision-Resistant Hash Functions

1. (15 points) **Hash Function Properties**
- (a) (5 points) Collision resistance:
 - i. Explain why collisions must exist in any hash function that maps arbitrary-length inputs to fixed-length outputs.
 - ii. Using the birthday paradox, calculate approximately how many hashes must be computed to find a collision with 50% probability in a 256-bit secure hash function.
 - iii. Describe a practical attack scenario where finding hash collisions would compromise a security system.
 - (b) (5 points) Hash function construction:
 - i. Compare and contrast the Merkle-Damgård construction (used in SHA-2) and the Sponge construction (used in SHA-3).

- ii. Explain how length extension attacks work against Merkle-Damgård hash functions and why the Sponge construction is resistant to these attacks.
 - iii. Describe the HMAC construction and explain how it protects against length extension attacks.
- (c) (5 points) Hash function evolution:
- i. Describe the successful attacks against MD5 and SHA-1 that led to their deprecation.
 - ii. Explain the concept of chosen-prefix collisions and why they are particularly dangerous for certificate authorities.
 - iii. Compare the security of SHA-2 and SHA-3 against known cryptanalytic techniques.
2. (15 points) **Password Hashing**
- (a) (5 points) For each of the following password storage approaches, analyze the security implications if a server database is compromised:
- i. Storing passwords in plaintext.
 - ii. Encrypting passwords with a key stored on the same server.
 - iii. Storing unsalted SHA-256 hashes of passwords.
 - iv. Storing salted SHA-256 hashes of passwords.
 - v. Using a specialized password hashing function like Scrypt.
- (b) (5 points) Salting:
- i. Explain how salt protects against precomputation attacks like rainbow tables.
 - ii. Calculate the storage requirements for properly salted password hashes, assuming 10,000 users, 16-byte salts, and 32-byte hash outputs.
 - iii. Describe best practices for generating and storing salts.
- (c) (5 points) Specialized password hashing functions:
- i. Explain why memory-hard functions like Scrypt provide better protection against specialized hardware attacks compared to PBKDF2.
 - ii. Describe how each of Scrypt's parameters (N , r , p) affect its security and performance.
 - iii. Compare the relative speeds of SHA-256, PBKDF2, and Scrypt for password hashing, and explain the security implications of these speed differences.

4 Applied Cryptography Case Studies

1. (10 points) **Block Cipher Modes Analysis**

With reference to the block cipher modes covered in our lectures, analyze the following scenarios:

- (a) A secure file storage application needs to encrypt user files at rest. Compare CBC, CTR, and AES-GCM modes for this application, discussing:
- Performance implications for large files.
 - Error propagation if parts of the ciphertext are corrupted.
 - The security implications of IV/nonce reuse.
 - Data integrity guarantees and the advantages of authenticated encryption with AES-GCM.
- (b) A real-time messaging application needs to encrypt short messages with minimal latency. Compare CBC, CTR, and AES-GCM modes for this application, discussing:
- Parallelizability for encryption/decryption.
 - Suitability for streaming data.
 - Protection against chosen-ciphertext attacks.
 - How AES-GCM addresses authentication needs compared to unauthenticated modes.
- (c) For AES-GCM specifically:
- Explain the security impact of nonce reuse in AES-GCM compared to nonce reuse in CTR mode.
 - Discuss the performance tradeoffs of AES-GCM compared to using separate encryption (CTR mode) and authentication (HMAC).
 - Explain how AES-GCM's authenticated encryption properties protect against attacks that would succeed against CBC or CTR modes.

2. (10 points) Hash Function Security Analysis

A software update system uses hash functions to verify the integrity of downloads. The system works as follows:

- The software vendor posts SHA-1 hashes of legitimate update files on their HTTPS website.
- Users download the update file over HTTP (not HTTPS) for bandwidth efficiency.
- The update client verifies the downloaded file by computing its SHA-1 hash and comparing it to the hash obtained from the HTTPS website.
- If the hashes match, the update is installed automatically.

Analyze this system:

- (a) Identify at least three security vulnerabilities in this design.
- (b) For each vulnerability, describe a specific attack scenario.
- (c) Propose improvements to address each vulnerability while maintaining performance and usability.
- (d) Design a more secure alternative system using modern cryptographic primitives discussed in class.

3. (10 points) Password Management System Design

You are designing a password management system for a new web application with the following requirements:

- Users must be able to securely recover their account if they forget their password.
- The system must be resistant to offline dictionary attacks if the database is compromised.
- The system must support high-performance authentication for a large user base.
- The system should detect and prevent credential stuffing attacks.

Design and analyze a complete solution:

- (a) Specify which cryptographic primitives you would use for password storage and why.
- (b) Describe your password recovery mechanism and analyze its security properties.
- (c) Explain how your system balances security and performance requirements.
- (d) Analyze potential vulnerabilities in your design and how they are mitigated.

Bonus Question

1. (10 points (bonus)) The security of AES and other block ciphers depends on their resistance to various forms of cryptanalysis. Research and analyze one of the following advanced attacks:

- (a) **Side-channel attacks:** Explain how timing attacks, power analysis, or cache attacks can leak information about encryption keys in practical implementations of AES.
- (b) **Related-key attacks:** Describe how related-key attacks work against block ciphers and why they are significant even when normal usage involves only unrelated keys.
- (c) **Quantum attacks:** Analyze the impact of Grover's algorithm on the security of AES with different key sizes (128, 192, 256 bits) and discuss appropriate post-quantum key length recommendations.

Your answer should include: a description of the attack, its practical feasibility, relevant examples of successful implementations against real systems, and appropriate countermeasures.